

Detección de phishing asistido por LLM mediante un enfoque multimodal y explicable basado en URL y texto

Gabriel A. Paz González

Facultad de Ingeniería, Universidad del Valle de Guatemala

Curso CC3094 - Security Data Science

Abstract— Phishing remains one of the most persistent cyber threats, and recent generative AI tools have reduced the effort required to craft convincing messages at scale. This paper presents a university-level research proposal for detecting modern phishing by combining URL entropy and lexical features with textual signals associated with the link, such as message snippets, email subjects, or landing-page prompts. The proposed method uses a multimodal pipeline: a URL feature branch, a transformer-based text branch, and a fusion classifier with cost-sensitive thresholding to control false positives under low base-rate conditions. In addition, the approach integrates SHAP-based explanations to improve transparency for analysts and end users. The experimental design considers temporal splits, domain-level validation, dataset shift, and ablation studies to compare URL-only, text-only, and fused models. Public data sources such as PhishTank, URLhaus, and UCI datasets are considered to support reproducibility. The expected contribution is a more robust and explainable detection strategy aligned with the current challenge of LLM-assisted phishing.

Index Terms—phishing, large language models, malicious URL detection, explainable AI, cybersecurity, multimodal classification.

I. INTRODUCCIÓN

El phishing sigue siendo una de las amenazas más persistentes en ciberseguridad, y el escenario actual es más complejo por el uso de herramientas generativas que facilitan la redacción de mensajes convincentes, personalizados y con menos errores. Reportes recientes de la Anti-Phishing Working Group (APWG) mantienen el tema como una prioridad operativa, mientras que el NCSC del Reino Unido ya advierte que la IA generativa reduce la barrera de entrada para tareas de ingeniería social y aumenta la eficiencia de los atacantes [1], [2].

En este contexto, una propuesta basada únicamente en la estructura de la URL se queda corta para representar el phishing moderno. Aunque la URL sigue siendo una señal importante, hoy muchas campañas combinan enlaces con texto bien redactado (correo, SMS, chat o formularios) que aparenta legitimidad. Por ello, este artículo plantea una propuesta metodológica que combina señales de URL y señales textuales dentro de un mismo pipeline de detección.

El objetivo principal es diseñar un enfoque reproducible, con criterios de evaluación realistas, que permita comparar el aporte de cada modalidad (URL y texto) y, además, provea explicaciones útiles para análisis humano. La contribución esperada no es proponer un modelo fundacional nuevo, sino integrar técnicas actuales en una arquitectura multimodal, explicable y aplicable en un entorno universitario.

II. TRABAJO RELACIONADO

A. Detección de URLs maliciosas

La detección de URLs maliciosas evolucionó desde listas negras hacia modelos de aprendizaje supervisado. Un trabajo clásico de referencia demostró que es posible detectar sitios maliciosos a partir de propiedades léxicas y de hosting de la URL, superando el enfoque de blacklist pura en capacidad de generalización [3]. Posteriormente, URLNet mostró que el aprendizaje profundo puede capturar patrones directamente desde la cadena de la URL (a nivel de caracteres y palabras), reduciendo la dependencia de feature engineering manual [4].

Más recientemente, también han aparecido enfoques con transformadores para URLs, como PhishTransformer, que combinan representación contextual y señales estructurales para mejorar la detección en escenarios modernos [5]. Estos

trabajos respaldan la idea de conservar una rama especializada en URL dentro del modelo propuesto.

B. Phishing moderno, texto y LLMs

La sofisticación del phishing actual no depende solo del enlace, sino del contexto textual que acompaña el ataque. En esta línea, Uddin y Sarker presentan un enfoque con transformadores explicables para detección de correos de phishing, mostrando que los modelos de lenguaje pueden integrarse con técnicas de explicabilidad para apoyar la toma de decisiones [6]. De forma complementaria, ChatSpamDetector explora el uso de LLMs para la detección de correos de phishing y evidencia el movimiento reciente del problema hacia enfoques con razonamiento semántico [7].

También existen comparativas recientes que evalúan modelos clásicos y transformadores en detección de phishing por correo, reportando ventajas consistentes de modelos basados en transformadores en escenarios con texto suficiente y datos balanceados [8]. Esto fortalece la decisión de incluir una rama textual en la propuesta.

C. Modelos base y explicabilidad

Para la representación textual, BERT y sus variantes siguen siendo una referencia práctica por su capacidad para generar embeddings contextuales reutilizables en clasificación [9]. Para la fusión de variables heterogéneas (léxicas, estadísticas y semánticas), XGBoost es una opción sólida por su rendimiento y eficiencia en datos tabulares [10]. Finalmente, SHAP proporciona explicaciones por instancia que resultan especialmente útiles cuando se necesita justificar por qué un enlace o mensaje fue marcado como sospechoso [11].

III. PREGUNTA DE INVESTIGACIÓN Y PROPUESTA

A. Pregunta de investigación

La pregunta central del trabajo es: ¿un clasificador multimodal que combine señales de URL y texto asociado al enlace mejora la detección de phishing asistido por LLM, en comparación con enfoques basados solo en URL, manteniendo un nivel aceptable de falsos positivos?

B. Hipótesis

La hipótesis principal es que la fusión de rasgos léxicos/estadísticos de URL con representaciones semánticas del texto incrementará el recall y la AUC-PR en escenarios realistas, especialmente cuando el mensaje fraudulento esté bien redactado. Se espera que la mejora sea más evidente en

ataques donde la URL por sí sola no exhibe señales extremas de sospecha.

C. Variables y representación

La rama de URL incluirá variables como entropía de Shannon, longitud total, número de subdominios, cantidad de dígitos, símbolos especiales, longitud del path, presencia de IP en el host, patrones de acortadores y rasgos asociados al TLD. La entropía se usa como señal de aleatoriedad, pero se considera un componente complementario y no suficiente por sí solo.

La rama textual procesará el contenido asociado al enlace: asunto de correo, fragmento del mensaje, anchor text o título de la página, dependiendo de la disponibilidad del dataset. Se proponen dos niveles de representación: (1) rasgos lingüísticos simples (urgencia, imperativos, solicitud de credenciales, presión temporal) y (2) embeddings contextuales con un modelo tipo BERT [9].

D. Fusión y clasificación

La fusión se implementará con un clasificador tabular (por ejemplo, XGBoost) que reciba variables de URL, señales de reglas simples y un vector resumido de la rama textual (por reducción de dimensionalidad o puntaje de modelo textual) [10]. Como línea base se compararán tres variantes: URL-only, text-only y una regresión logística con features manuales.

Además, se definirá una política de umbral orientada a costo para controlar falsos positivos, ya que en ambientes reales el costo de alertar en exceso puede afectar la adopción del sistema. Este punto es importante porque accuracy, por sí sola, no refleja el comportamiento deseado en ciberseguridad.

E. Explicabilidad operativa

La propuesta integra SHAP para generar explicaciones por instancia [11]. La salida del sistema no será únicamente una etiqueta, sino una clasificación acompañada de razones breves y accionables, por ejemplo: “subdominios excesivos y alta entropía” o “mensaje con urgencia y solicitud de inicio de sesión”. Este componente busca que la solución sea útil tanto para análisis técnico como para capacitación de usuarios.

IV. DISEÑO EXPERIMENTAL

A. Datos

Se propone trabajar con fuentes públicas y trazables. Para conjuntos de referencia tabulares, se consideran el dataset Phishing Websites de UCI [12] y el dataset PhiUSIIL de UCI [13], este último con mayor volumen, variables más recientes y una conexión directa con su paper introductorio [14]. Para URLs maliciosas observadas en operación real, se utilizarán fuentes comunitarias como URLhaus y PhishTank [15], [16].

Como no todos los datasets incluyen texto del mensaje, el estudio se dividirá en dos escenarios: (1) evaluación URL-only sobre datasets tabulares consolidados y (2) evaluación multimodal sobre un subconjunto donde exista texto asociado al enlace. Esta separación evita mezclar resultados y permite medir con claridad el aporte de la modalidad textual.

B. Partición y validación

Para reducir leakage, se priorizará una partición temporal (entrenamiento con muestras más antiguas y prueba con muestras más recientes) cuando la fuente lo permita.

Adicionalmente, se propone validación por dominio raíz para evitar que URLs muy similares aparezcan en entrenamiento y prueba. Esta decisión es importante porque muchas métricas infladas en phishing provienen de particiones aleatorias poco realistas.

C. Métricas

Las métricas principales serán precisión, recall, F1 y AUC-PR. Se prioriza AUC-PR sobre accuracy por el desbalance de clases y la baja tasa base de eventos maliciosos en despliegues reales. También se reportarán curvas precision-recall y una evaluación de umbrales para mostrar el compromiso entre sensibilidad y falsos positivos.

D. Ablaciones y robustez

Se plantean pruebas de ablación para medir el aporte de cada componente: (i) sin entropía, (ii) sin texto, (iii) sin rasgos lingüísticos manuales y (iv) sin capa de explicabilidad. Además, se evaluará robustez frente a ofuscación común (subdominios largos, inserción de marcas en rutas, acortadores) y mensajes con tono corporativo o lenguaje más natural.

V. APORTE ESPERADO Y DISCUSIÓN

La propuesta responde al comentario del curso al desplazar el enfoque desde phishing “tradicional” hacia phishing asistido por LLM. La novedad del trabajo no radica en crear un algoritmo completamente nuevo, sino en construir una metodología moderna y bien evaluada que combine señales heterogéneas, considere escenarios de generalización y sea interpretable.

En términos académicos, el proyecto permite integrar conceptos de ciencia de datos, procesamiento de lenguaje natural, ciberseguridad y evaluación experimental. En términos prácticos, la capa de explicabilidad puede aportar valor para analistas o para campañas de concientización, ya que permite explicar de forma entendible por qué un caso fue considerado riesgoso.

Entre las limitaciones previstas están la disponibilidad desigual de texto asociado a las URLs, la deriva temporal de los patrones de phishing y la posible diferencia entre datasets públicos y datos reales de una organización. Por ello, se recomienda documentar claramente el periodo de recolección y reportar resultados por escenario.

VI. CONCLUSIONES

Se presentó una propuesta de investigación para detectar phishing asistido por LLM mediante un enfoque multimodal y explicable que combina señales de URL y texto. La metodología planteada busca modernizar una línea clásica de detección de phishing y alinearla con el contexto actual, donde el texto generado por IA eleva la calidad de los ataques.

Como trabajo futuro, una vez definido el corpus textual, será posible comparar alternativas de representación (BERT, modelos ligeros o LLMs) y medir el balance entre costo computacional, desempeño y explicabilidad. Con ello, el proyecto puede evolucionar desde una propuesta metodológica hacia un prototipo experimental con resultados reproducibles.

REFERENCIAS

- [1] Anti-Phishing Working Group (APWG), "Phishing Activity Trends Reports," APWG. [Online]. Available: <https://apwg.org/trendsreports/>. [Accessed: Feb. 24, 2026].
- [2] National Cyber Security Centre (NCSC), "The near-term impact of AI on the cyber threat," 2024. [Online]. Available: <https://www.ncsc.gov.uk/report/impact-of-ai-on-cyber-threat>. [Accessed: Feb. 24, 2026].
- [3] J. Ma, L. K. Saul, S. Savage, and G. M. Voelker, "Beyond blacklists: Learning to detect malicious web sites from suspicious URLs," in Proc. 15th ACM SIGKDD Int. Conf. Knowledge Discovery and Data Mining (KDD), 2009, pp. 1245-1254, doi: 10.1145/1557019.1557153.
- [4] H. Le, Q. Pham, D. Sahoo, and S. C. H. Hoi, "URLNet: Learning a URL Representation with Deep Learning for Malicious URL Detection," CoRR, abs/1802.03162, 2018. [Online]. Available: <https://arxiv.org/abs/1802.03162>.
- [5] M. M. Asiri et al., "PhishTransformer: Phishing URL Detection Using a Hybrid Transformer-Based Approach," Electronics, vol. 13, no. 1, Art. no. 30, 2024, doi: 10.3390/electronics13010030.
- [6] M. A. Uddin and I. H. Sarker, "An Explainable Transformer-based Model for Phishing Email Detection: A Large Language Model Approach," CoRR, abs/2402.13871, 2024, doi: 10.48550/arXiv.2402.13871.
- [7] T. Koide, N. Fukushi, H. Nakano, and D. Chiba, "ChatSpamDetector: Leveraging Large Language Models for Effective Phishing Email Detection," CoRR, abs/2402.18093, 2024, doi: 10.48550/arXiv.2402.18093.
- [8] H. A. Meléndez et al., "Comparative Investigation of Machine Learning and Transformer-Based Deep Learning Algorithms for Phishing Email Detection," Electronics, vol. 13, no. 24, Art. no. 4877, 2024, doi: 10.3390/electronics13244877.
- [9] J. Devlin, M.-W. Chang, K. Lee, and K. Toutanova, "BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding," CoRR, abs/1810.04805, 2018. [Online]. Available: <https://arxiv.org/abs/1810.04805>.
- [10] T. Chen and C. Guestrin, "XGBoost: A Scalable Tree Boosting System," in Proc. 22nd ACM SIGKDD Int. Conf. Knowledge Discovery and Data Mining (KDD), 2016, pp. 785-794, doi: 10.1145/2939672.2939785.
- [11] S. M. Lundberg and S.-I. Lee, "A Unified Approach to Interpreting Model Predictions," in Adv. Neural Inf. Process. Syst. (NeurIPS), 2017, pp. 4765-4774.
- [12] R. Mohammad and L. McCluskey, "Phishing Websites" [Dataset], UCI Machine Learning Repository, 2012, doi: 10.24432/C51W2X.
- [13] UC Irvine Machine Learning Repository, "PhiUSIIL Phishing URL (Website)" [Dataset], 2024. [Online]. Available: <https://archive-beta.ics.uci.edu/dataset/967/phiusiil%2Bphishing%2Burl%2Bdataset>. [Accessed: Feb. 24, 2026].
- [14] A. Prasad and S. Chandra, "PhiUSIIL: A diverse security profile empowered phishing URL detection framework based on similarity index and incremental learning," Computers & Security, 2024, doi: 10.1016/j.cose.2023.103545.
- [15] abuse.ch, "URLhaus API," URLhaus. [Online]. Available: <https://urlhaus.abuse.ch/api/>. [Accessed: Feb. 24, 2026].
- [16] PhishTank, "Developer Information," PhishTank. [Online]. Available: https://dev.phishtank.com/developer_info.php. [Accessed: Feb. 24, 2026].